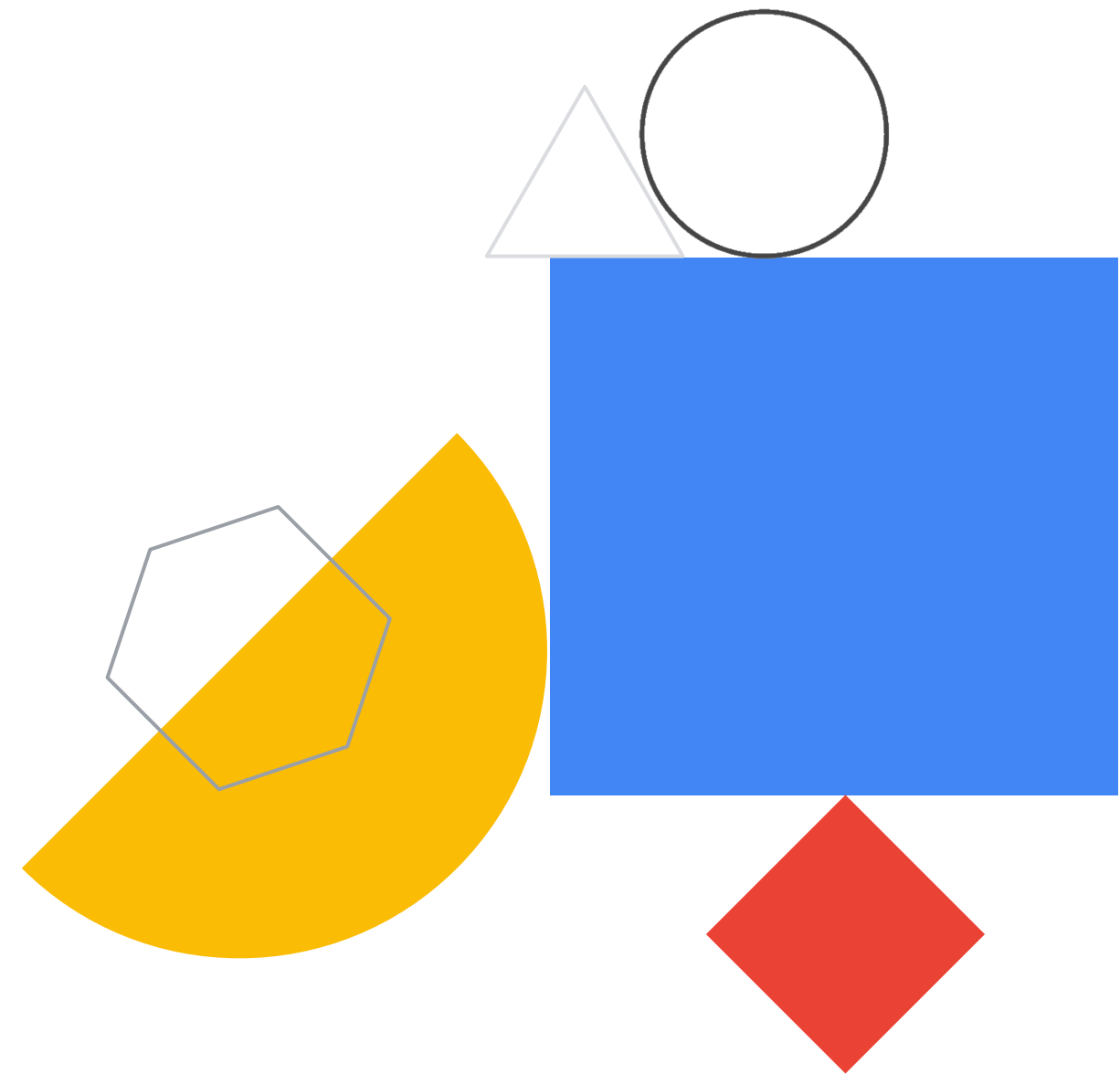


# Identity and Access Management



# 주제

01 Identity and Access Management(IAM)

02 조직

03 역할

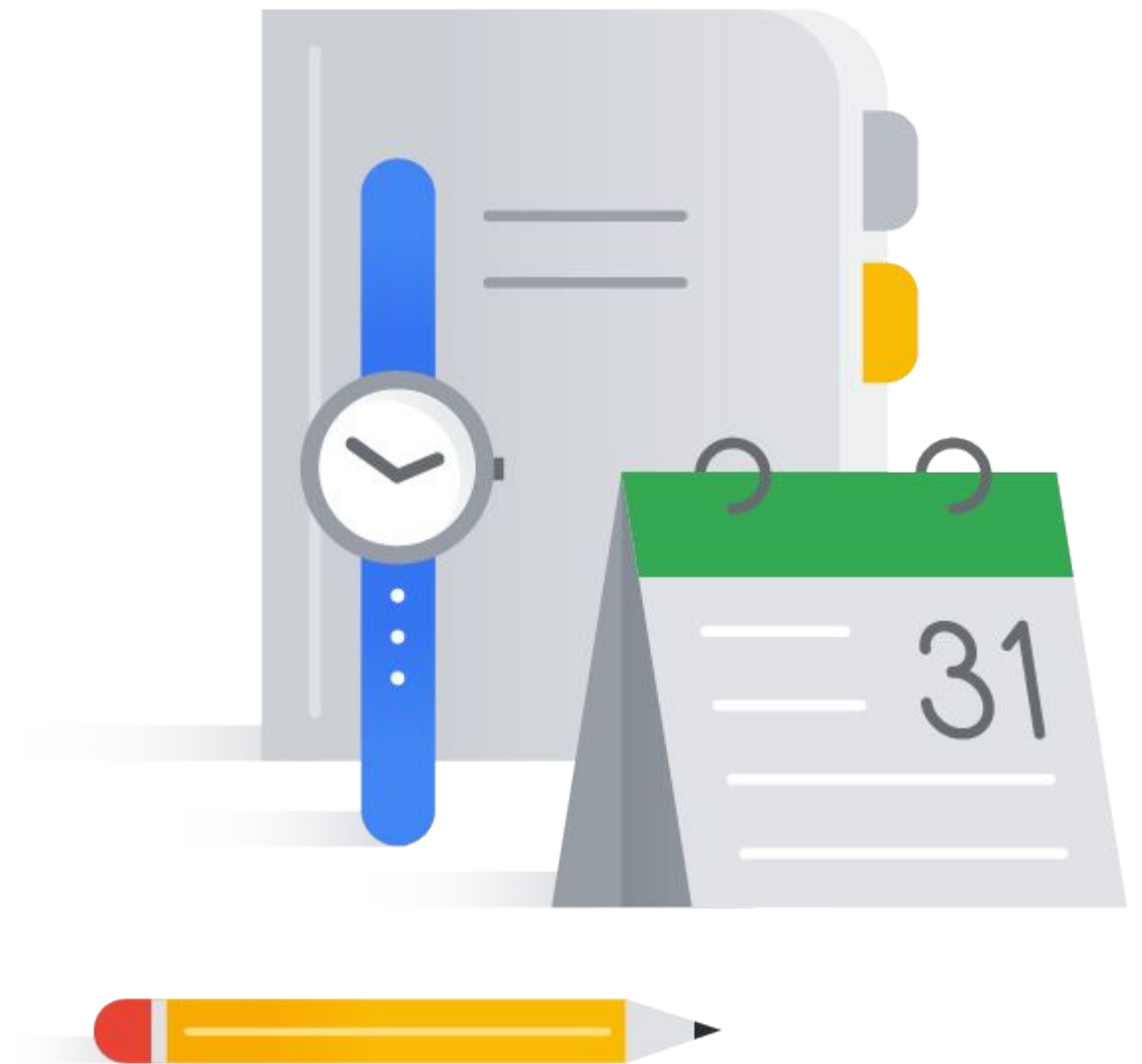
04 구성원

05 서비스 계정

06 조직 액세스 제한

07 IAM 권장사항

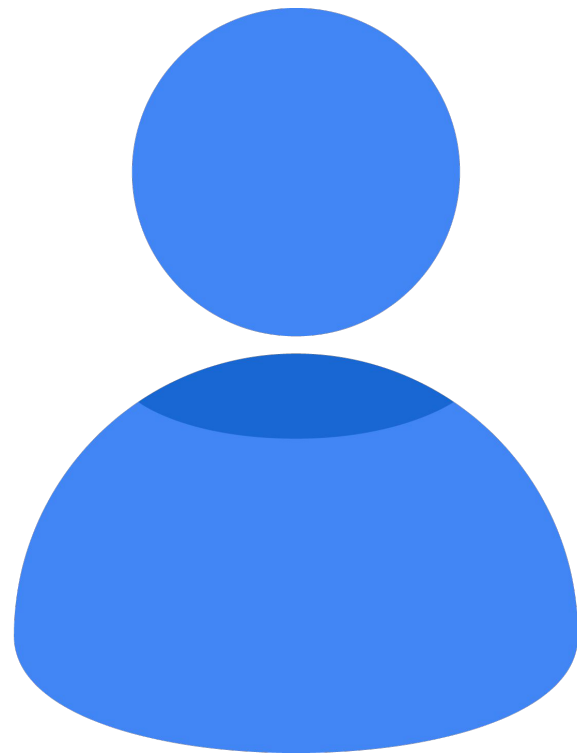
실습: IAM 살펴보기



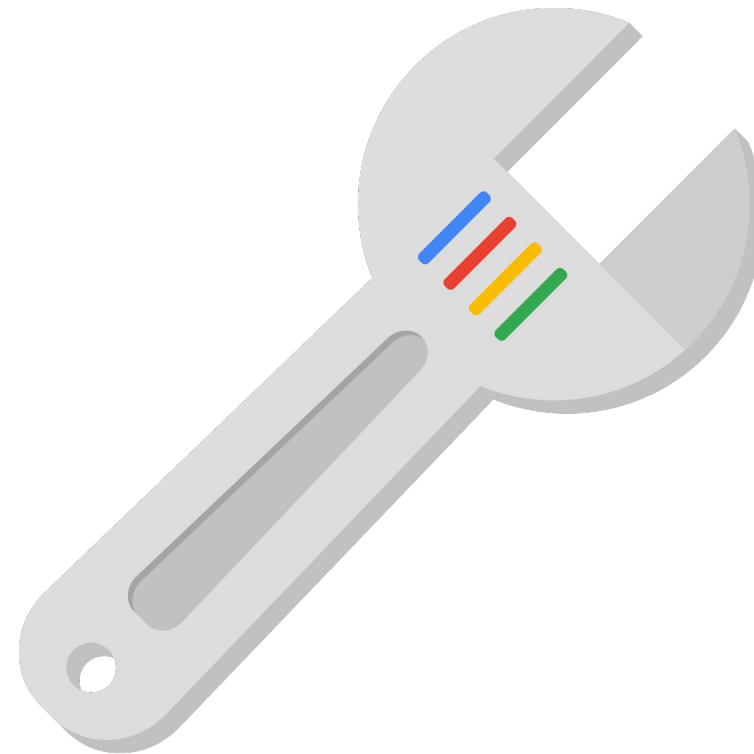


# Identity and Access Management(IAM)

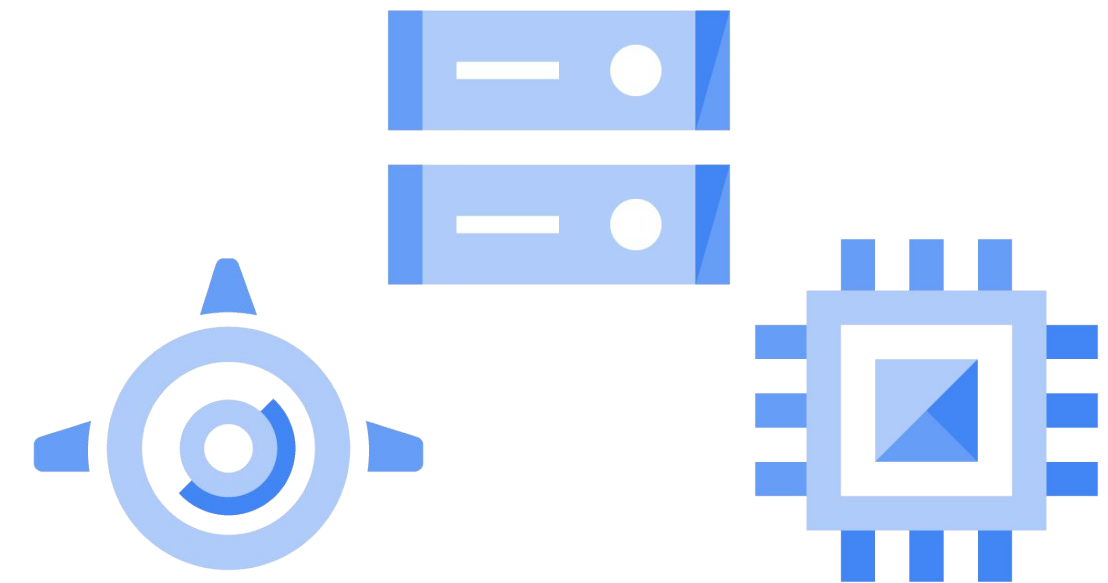
# Identity and Access Management



누가

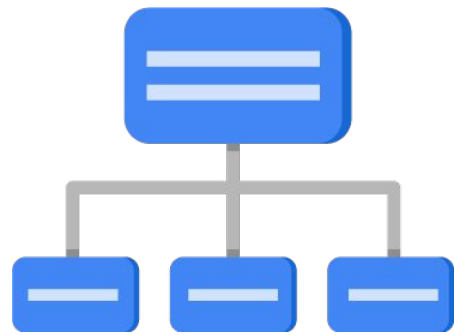


무엇을 할 수 있는지



어떤 리소스에서

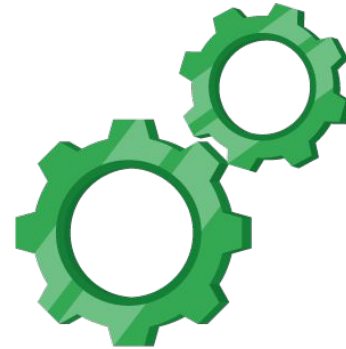
# IAM 객체



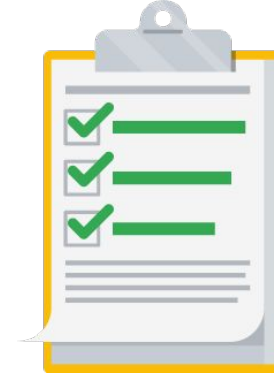
조직



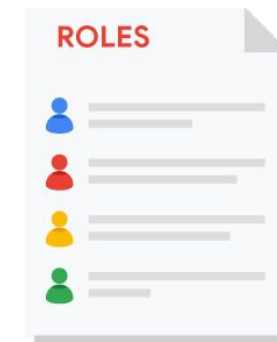
폴더



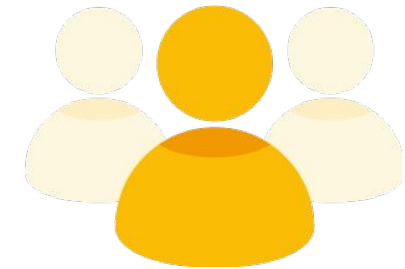
프로젝트



리소스



역할



구성원



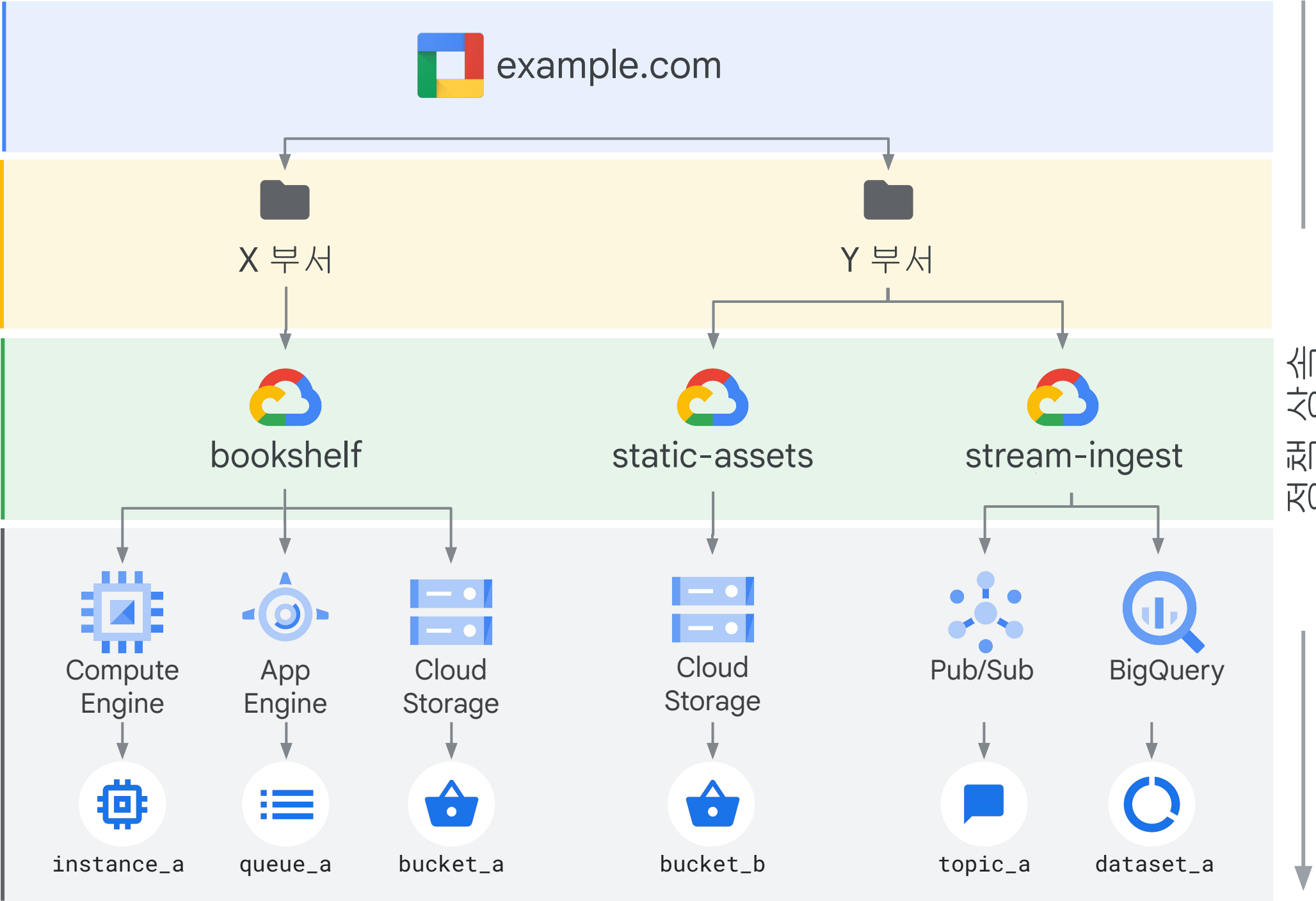
# IAM 리소스 계층 구조

1 조직

2 폴더

3 프로젝트

4 리소스

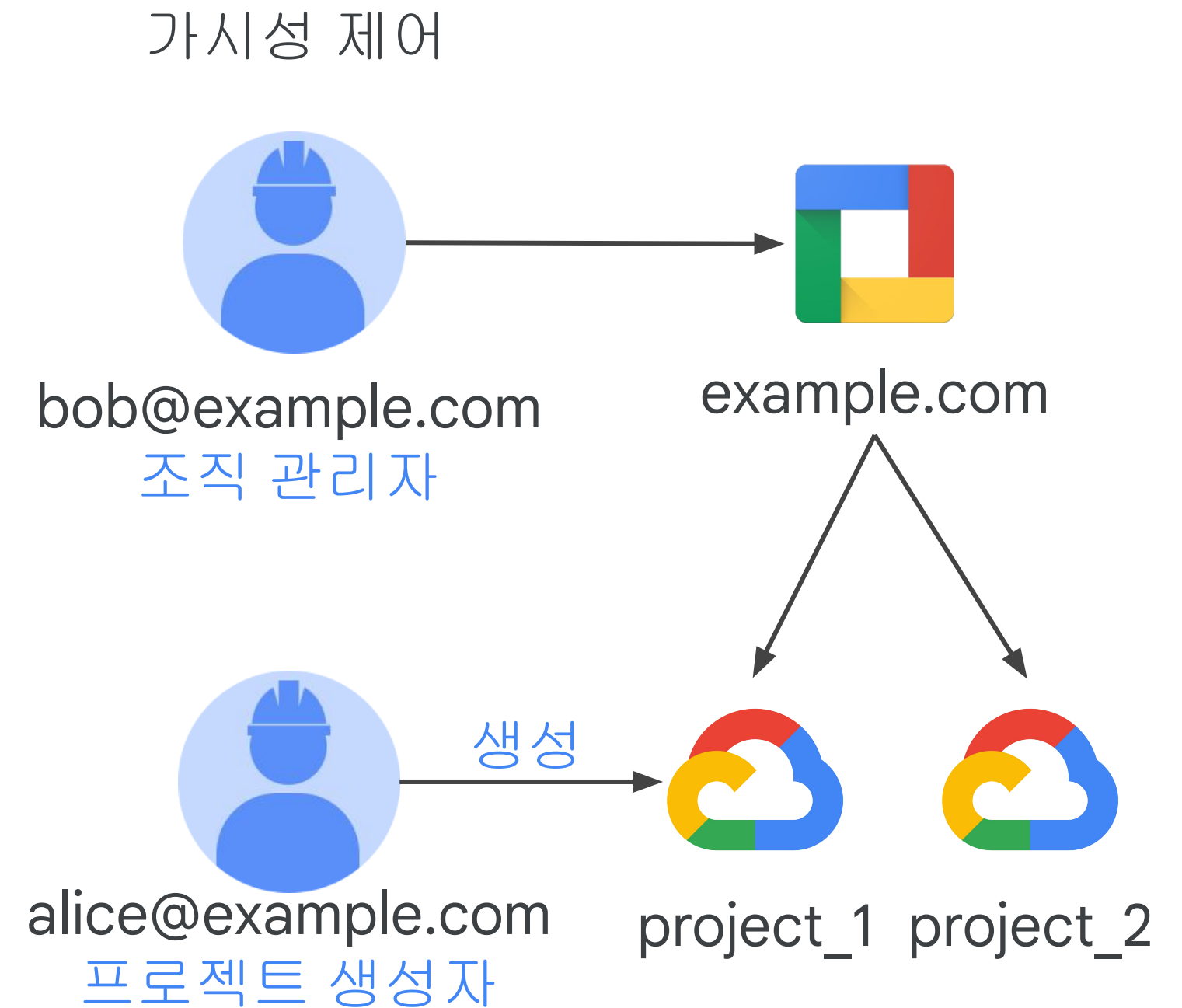




조직

# 조직 노드

- 조직 노드는 Google Cloud 리소스의 루트 노드입니다.
- 조직 역할:
  - 조직 관리자: 모든 클라우드 리소스를 제어할 수 있습니다. 감사에 유용합니다.
  - 프로젝트 생성자: 프로젝트의 생성을 제어할 수 있습니다. 누가 프로젝트를 생성할 수 있는지 제어합니다.

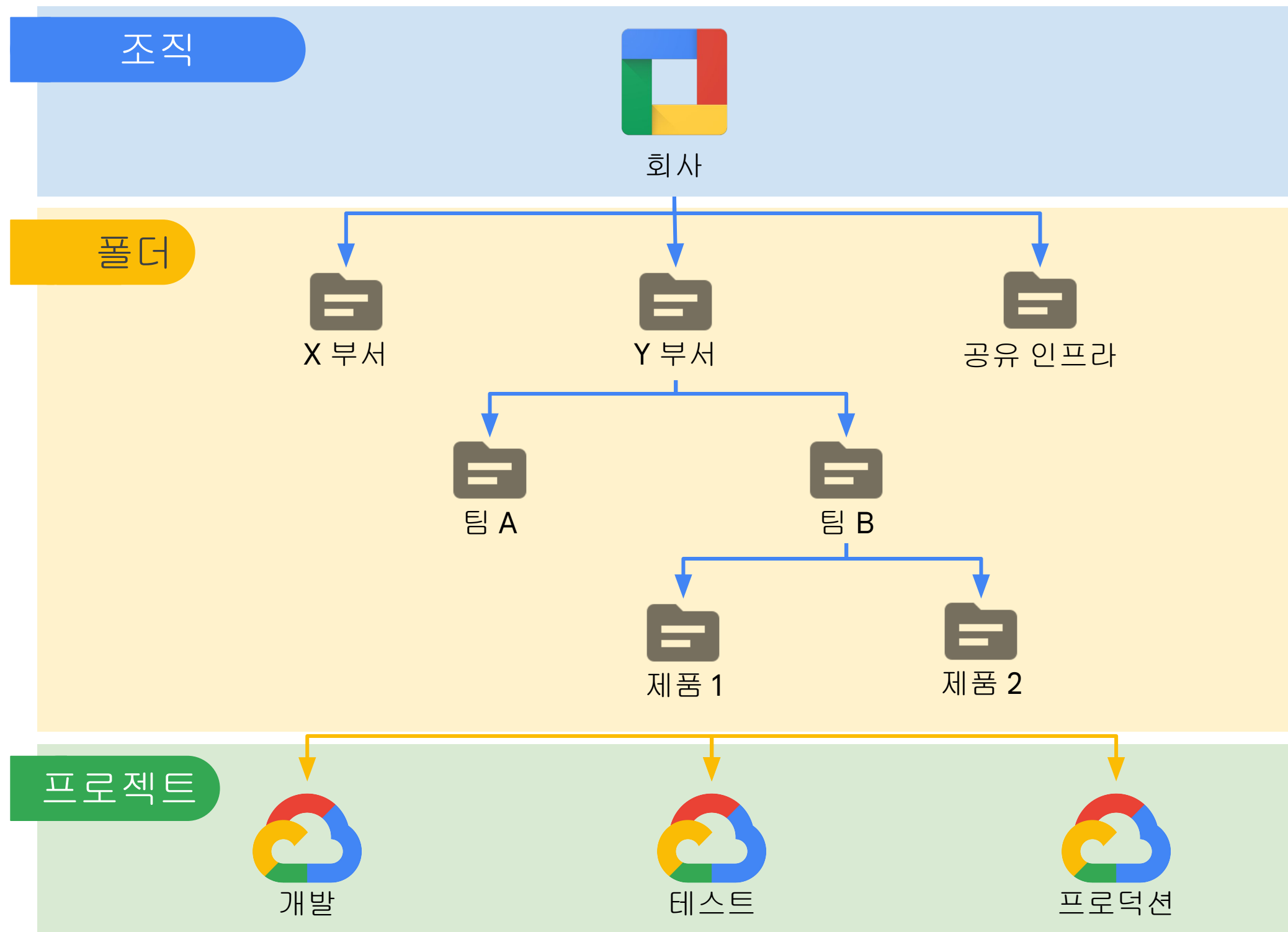




# 조직 만들기 및 관리하기

- **Google Workspace** 또는 **Cloud ID** 계정이 Google Cloud 프로젝트를 생성하면 생성됨
- **Workspace** 또는 **Cloud ID** 최고 관리자:
  - 일부 사용자에게 조직 관리자 역할을 할당합니다.
  - 복구 문제가 발생할 경우 담당자 역할을 수행합니다.
  - **Workspace** 또는 **Cloud ID** 계정 및 조직 리소스의 수명 주기를 제어합니다.
- 조직 관리자:
  - IAM 정책을 정의합니다.
  - 리소스 계층 구조를 결정합니다.
  - IAM 역할을 통해 네트워킹, 결제 및 리소스 계층 구조와 같은 중요한 구성요소에 대한 책임을 위임합니다.

# 폴더



프로젝트 간의 추가 그룹화  
메커니즘 및 격리 경계:

- 다양한 법인
- 부서
- 팀

폴더를 통해 관리 권한을 위임할  
수 있습니다.

# 리소스 관리자 역할

## 조직

- 관리자: 모든 리소스를 완전히 제어
- 뷰어: 모든 리소스에 대한 보기 권한

## 폴더

- 관리자: 모든 폴더를 완전히 제어
- 작성자: 계층 구조 탐색 및 폴더 생성
- 뷰어: 리소스 아래의 폴더 및 프로젝트 보기

## 프로젝트

- 작성자: 새 프로젝트 생성(자동 소유자) 및 새 프로젝트를 조직으로 마이그레이션
- 삭제자: 프로젝트 삭제





영향

# IAM 역할의 세 가지 유형

기본 역할



사전 정의된 역할



커스텀 역할





# 프로젝트의 모든 Google Cloud 서비스에 적용되는 IAM 기본 역할



무엇을 할 수 있는지



모든 리소스에서

# 대략적인 고정 액세스 수준을 제공하는 IAM의 기본 역할



# 프로젝트의 특정 Google Cloud 서비스에 적용되는 IAM의 사전 정의된 역할



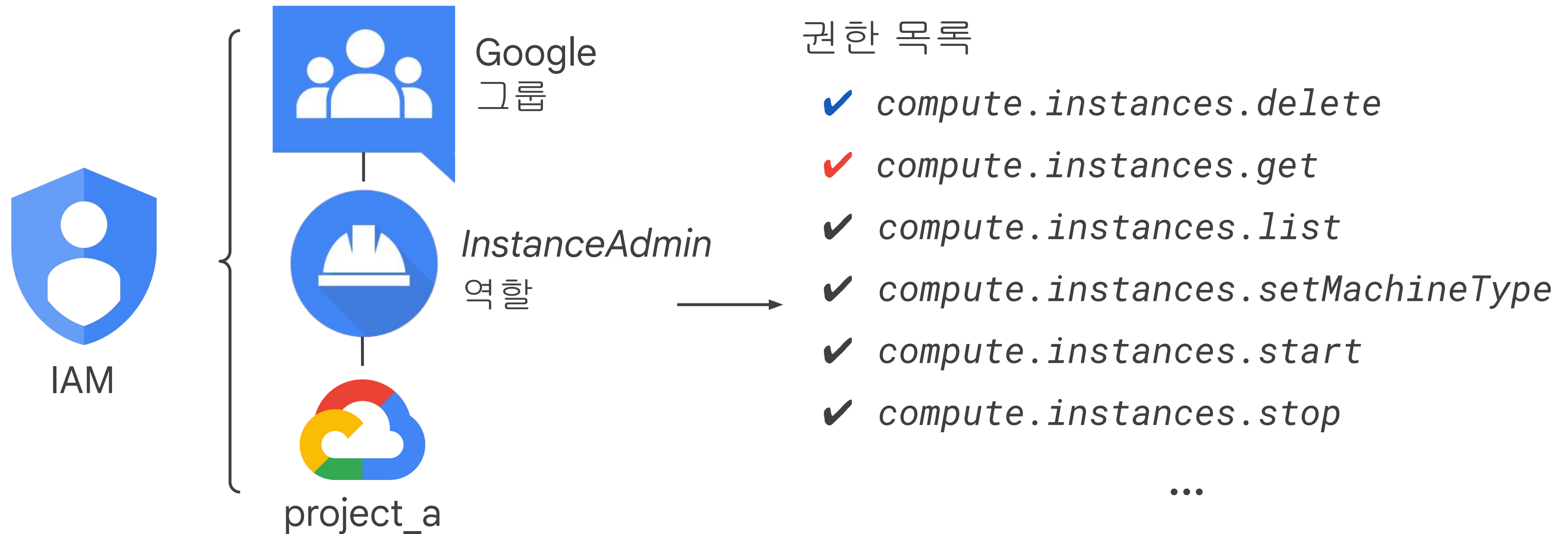
무엇을 할 수 있는지



이 프로젝트, 폴더 또는 조직의  
Compute Engine 리소스에서



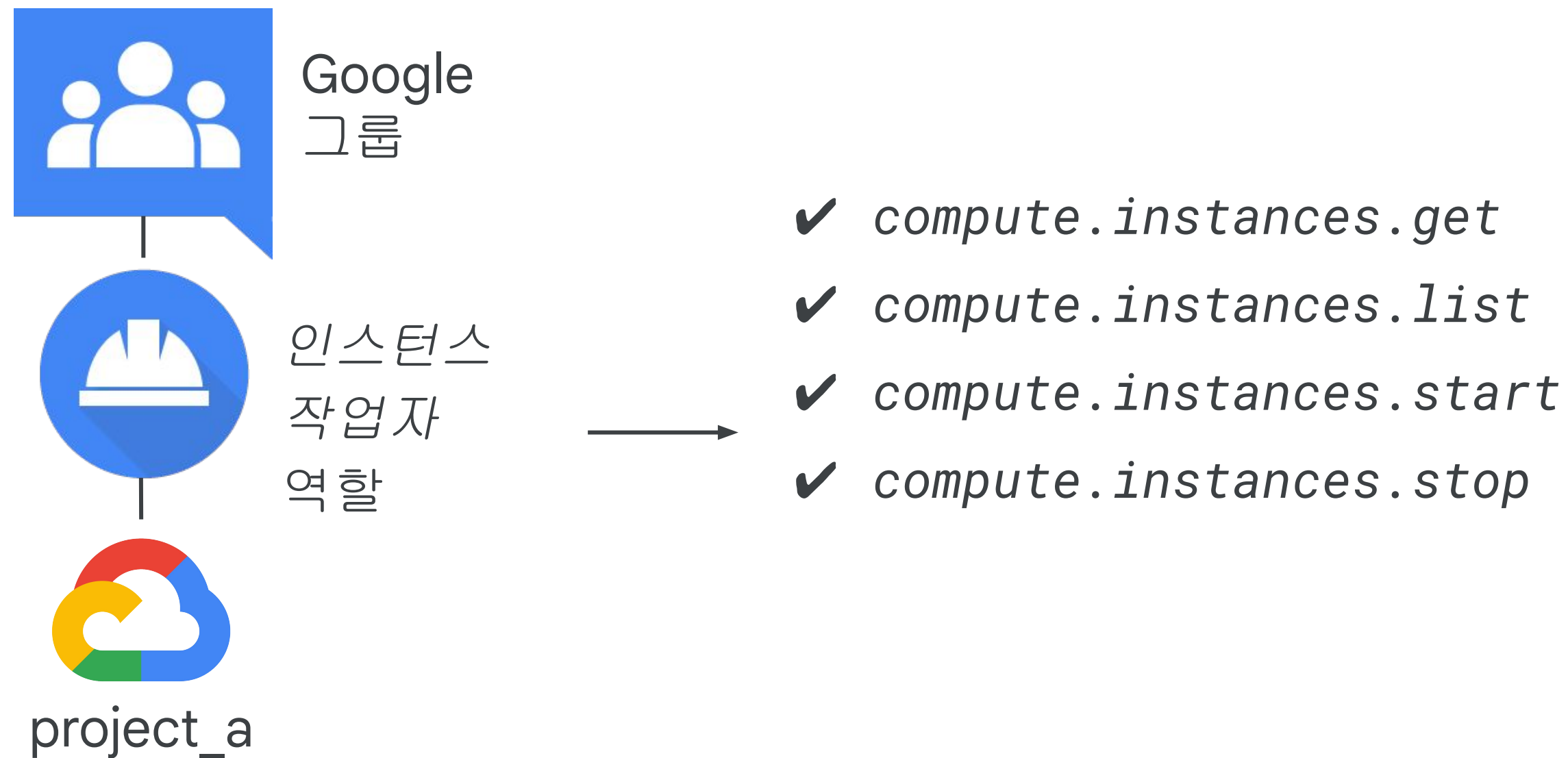
# 특정 서비스에 대해 보다 세분화된 권한을 제공하는 IAM의 사전 정의된 역할



# Compute Engine IAM 역할

| 역할 이름       | 설명                                                 |
|-------------|----------------------------------------------------|
| Compute 관리자 | 모든 Compute Engine 리소스를 관리할 수 있는 전체 권한(compute.*)   |
| 네트워크 관리자    | 방화벽 규칙과 SSL 인증서를 제외한 네트워킹 리소스를 생성, 수정, 삭제할 수 있는 권한 |
| 스토리지 관리자    | 디스크, 이미지, 스냅샷을 생성, 수정, 삭제할 수 있는 권한                 |

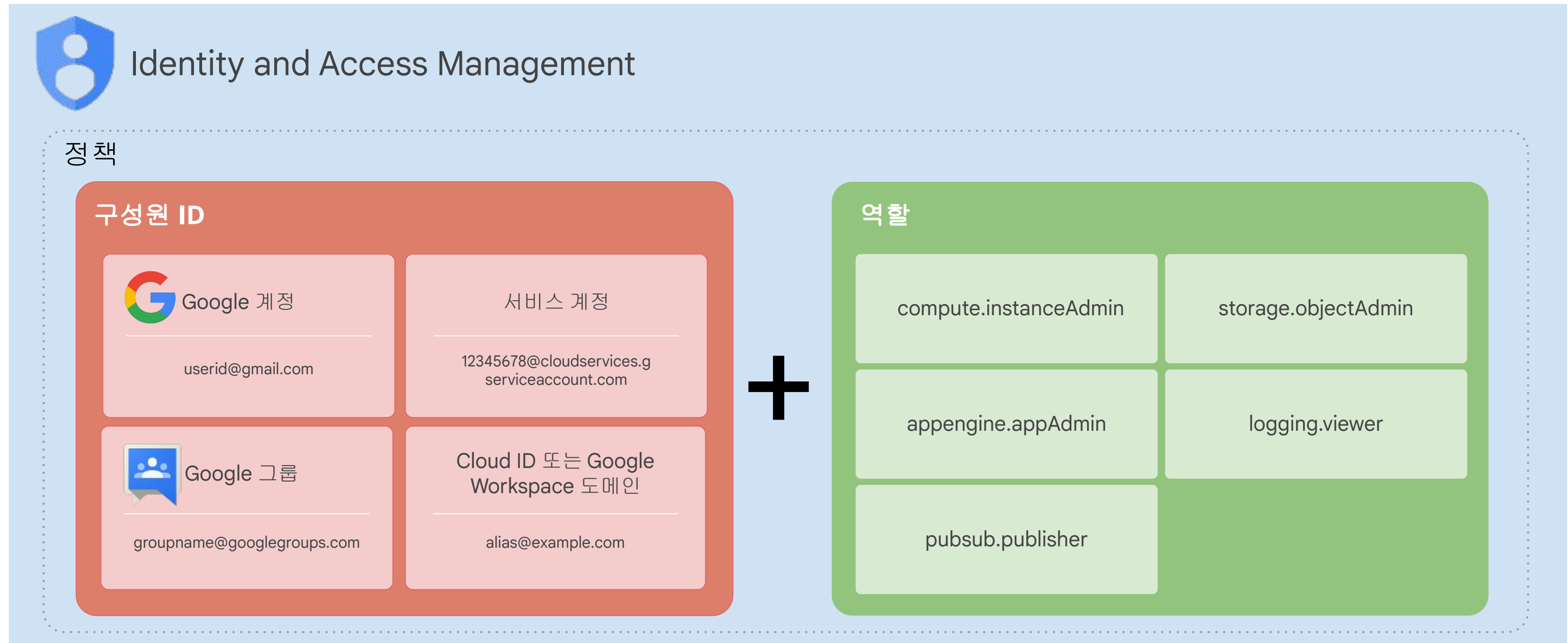
# IAM 커스텀 역할을 통해 정확한 권한 집합을 정의할 수 있음





## 구성원

# 구성원

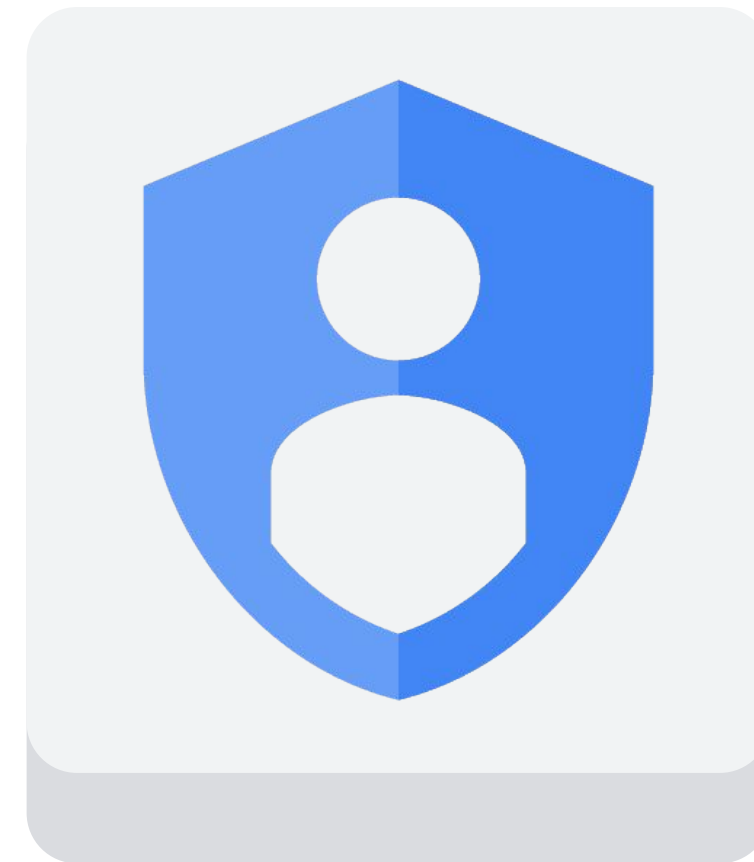


참고: IAM을 사용자 또는 그룹을 생성하거나 관리하는 데 사용할 수 없습니다.



# IAM 정책

- 정책은 바인딩의 목록으로 구성됩니다.
- 바인딩은 구성원 목록을 역할에 연결합니다.



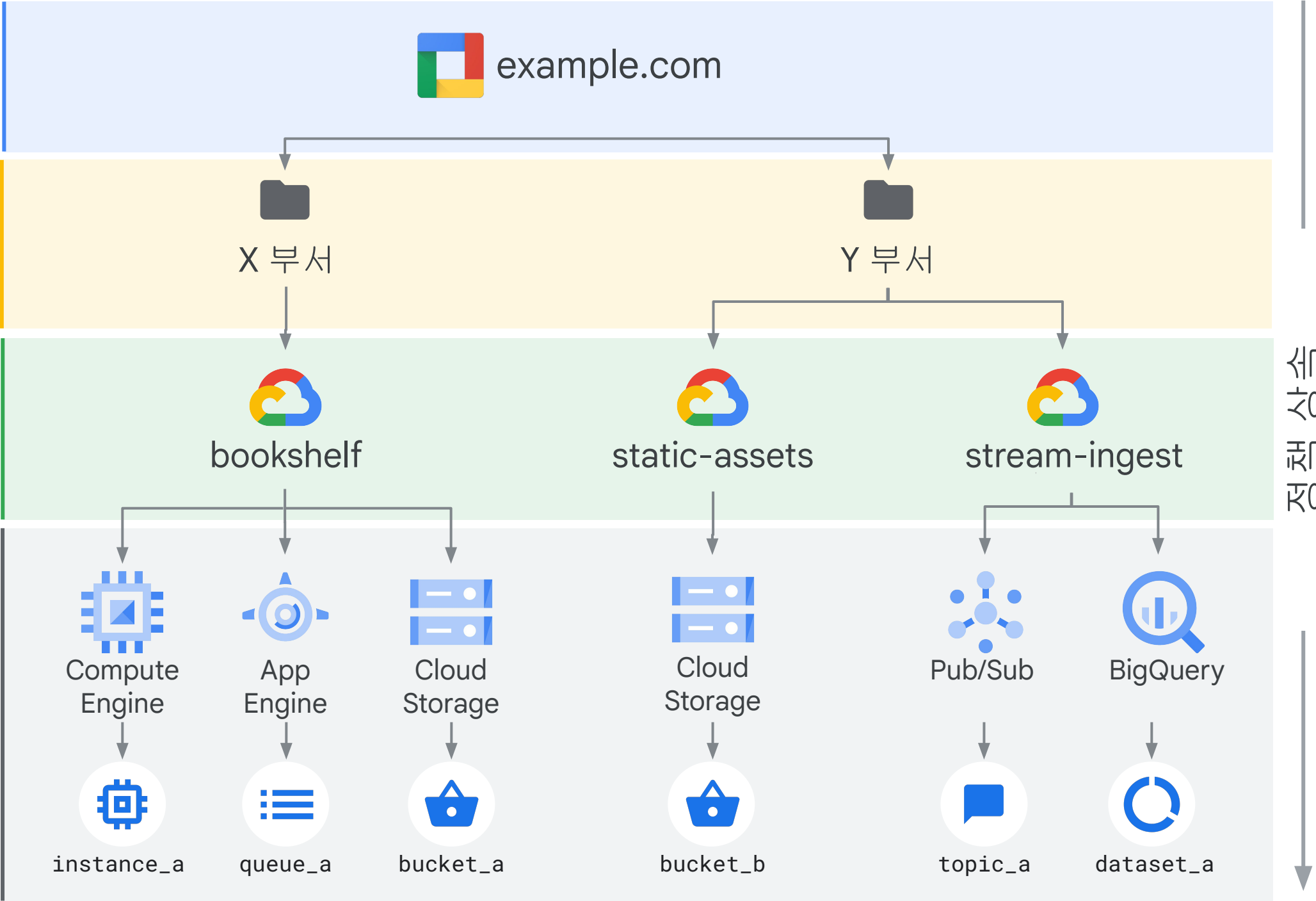
# IAM 리소스 계층 구조

1 조직

2 폴더

3 프로젝트

4 리소스



# IAM 허용 정책

- Google Cloud 리소스에 대해 액세스 권한 부여
- 리소스 자체 및 해당 리소스의 하위 요소에 대한 액세스 제어
- 단일 IAM 역할을 1명 이상의 주 구성원 (구성원 또는 ID라고도 함)과 연결하거나 바인딩

```
{
  "bindings": [
    {
      "members": [
        "user:jie@example.com"
      ],
      "role": "roles/resourcemanager.organizationAdmin"
    },
    {
      "members": [
        "user:raha@example.com",
        "user:jie@example.com"
      ],
      "role": "roles/resourcemanager.projectCreator"
    }
  ],
  "etag": "BwUjMhCsNvY=",
  "version": 1
}
```



# IAM 거부 정책

거부 규칙은 부여된 역할에 관계없이 특정 주 구성원이 특정 권한을 사용하지 못하게 할 수 있습니다.

거부 정책은 거부 규칙으로 구성됩니다. 각 거부 규칙은 다음을 지정합니다.

- 권한이 거부된 주 구성원 집합
- 주 구성원이 거부되거나 사용할 수 없는 권한
- 선택사항: 권한이 거부되려면 반드시 '참'이어야 하는 조건

권한이 거부된 주 구성원은 해당 권한이 필요한 작업을 수행할 수 없게 됩니다.

# IAM 조건

Google Cloud 리소스에 대한 속성 기반 조건부 액세스 제어를 시행합니다.

- 구성된 조건을 충족하는 경우에 한해 ID(구성원)에게 리소스에 액세스할 권한을 부여합니다.
- 리소스의 IAM 정책 중 역할 바인딩에서 지정됩니다.

# 조직 정책

조직 정책은...

- 제한사항의 구성입니다.
- 원하는 제한사항으로 제약조건을 구성하여 정의됩니다.
- 조직 노드, 폴더 또는 프로젝트에 적용됩니다.

# 이미 다른 회사 디렉터리가 있는 경우

Microsoft Active  
Directory 또는  
LDAP

기존 디렉터리 서비스의  
사용자 및 그룹

Google Cloud  
디렉터리 동기화

예약된 단방향 동기화



Cloud ID 도메인의 사용자  
및 그룹

# 싱글 사인온(SSO)

- Cloud ID를 사용하여 SAML SSO를 구성합니다.
- SAML2가 지원되지 않는 경우 서드 파티 솔루션(ADFS, Ping 또는 Okta)을 사용합니다.

☐ Setup SSO with third party identity provider

To setup third party as your identity provider, please provide the information below. ?

Sign-in page URL

URL for signing in to your system and G Suite

Sign-out page URL

URL for redirecting users to when they sign out

Change password URL

URL to let users change their password in your system; when defined here, this is shown even when Single Sign-on is not enabled

Verification certificate

CHOOSE FILE

No file chosen

UPLOAD

The certificate file must contain the public key for Google to verify sign-in requests. ?

☐ Use a domain specific issuer ?



# Gmail을 사용하지 않는 Google Cloud 액세스

## Create your Google Account

One account is all you need

One free account gets you into everything Google.










Take it all with you

Switch between devices, and pick up wherever you left off.





**Name**

**Your email address**

[I would like a new Gmail address](#)

**Create a password**

**Confirm your password**

**Birthday**

Month

Day

Year

**Gender**

I am...

**Mobile phone**

+1

**Location**

United States

[Next step](#)

- Gmail 없이도 Google 비밀번호를 얻을 수 있습니다.
- 도메인이 있으면 그룹 권한을 비롯해 여러 가지 이점이 있습니다.



## 서비스 계정

# 서비스 간 상호작용을 수행하기 위한 **ID**를 제공하는 서비스 계정

- Compute Engine 인스턴스 내에서 실행되는 프로그램은 사용자 인증 정보가 있는 액세스 토큰을 자동으로 얻을 수 있습니다.
- 토큰은 프로젝트의 모든 서비스 **API** 및 해당 서비스 계정에 액세스 권한이 부여된 기타 서비스에 액세스하는 데 사용됩니다.
- 서비스 계정은 사용자 데이터에 액세스하지 않을 경우에 편리합니다.



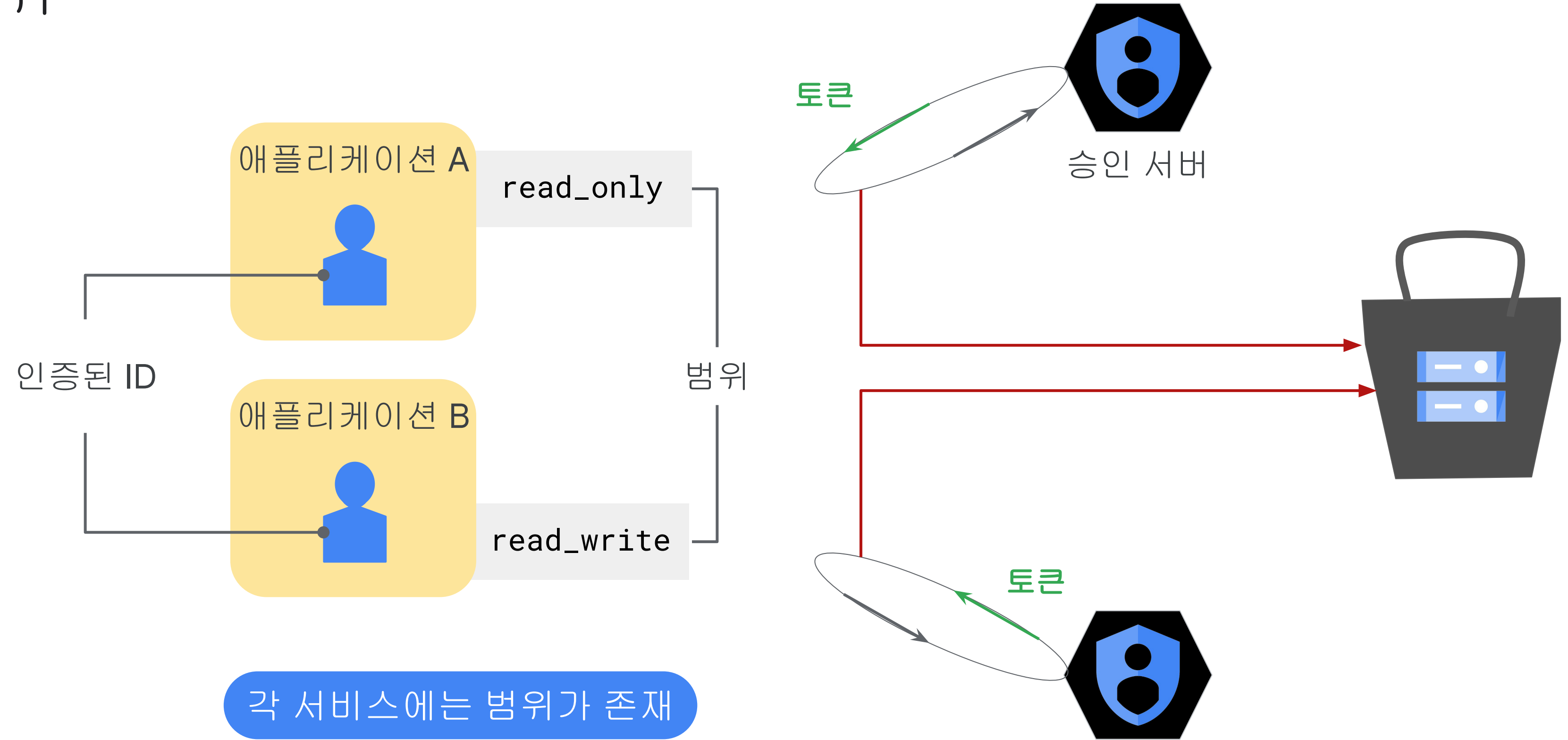
# 이메일 주소로 식별되는 서비스 계정

- 123845678986-compute@project.gserviceaccount.com
- 세 가지 유형의 서비스 계정:
  - 사용자 생성(커스텀)
  - 기본 제공
    - Compute Engine 및 App Engine 기본 서비스 계정
  - Google API 서비스 계정
    - 사용자를 대신하여 내부 Google 프로세스 실행

# 기본 Compute Engine 서비스 계정

- 자동 생성된 이름 및 이메일 주소를 사용하여 프로젝트별로 자동 생성:
  - 이름에 -compute 접미사가 있습니다.  
`39xxxx0965-compute@developer.gserviceaccount.com`
- 프로젝트 편집자로 자동 추가됨
- 기본적으로 gcloud 또는 Google Cloud 콘솔을 사용하여 생성된 모든 인스턴스에서 사용 설정됨

# 범위



# VM 범위 맞춤설정

Identity and API access ?

Service account ?

Compute Engine default service account ▼

Access scopes ?

☐ Allow default access

☐ Allow full access to all Cloud APIs

☒ Set access for each API

BigQuery

None

Bigtable Admin

None

Bigtable Data

None

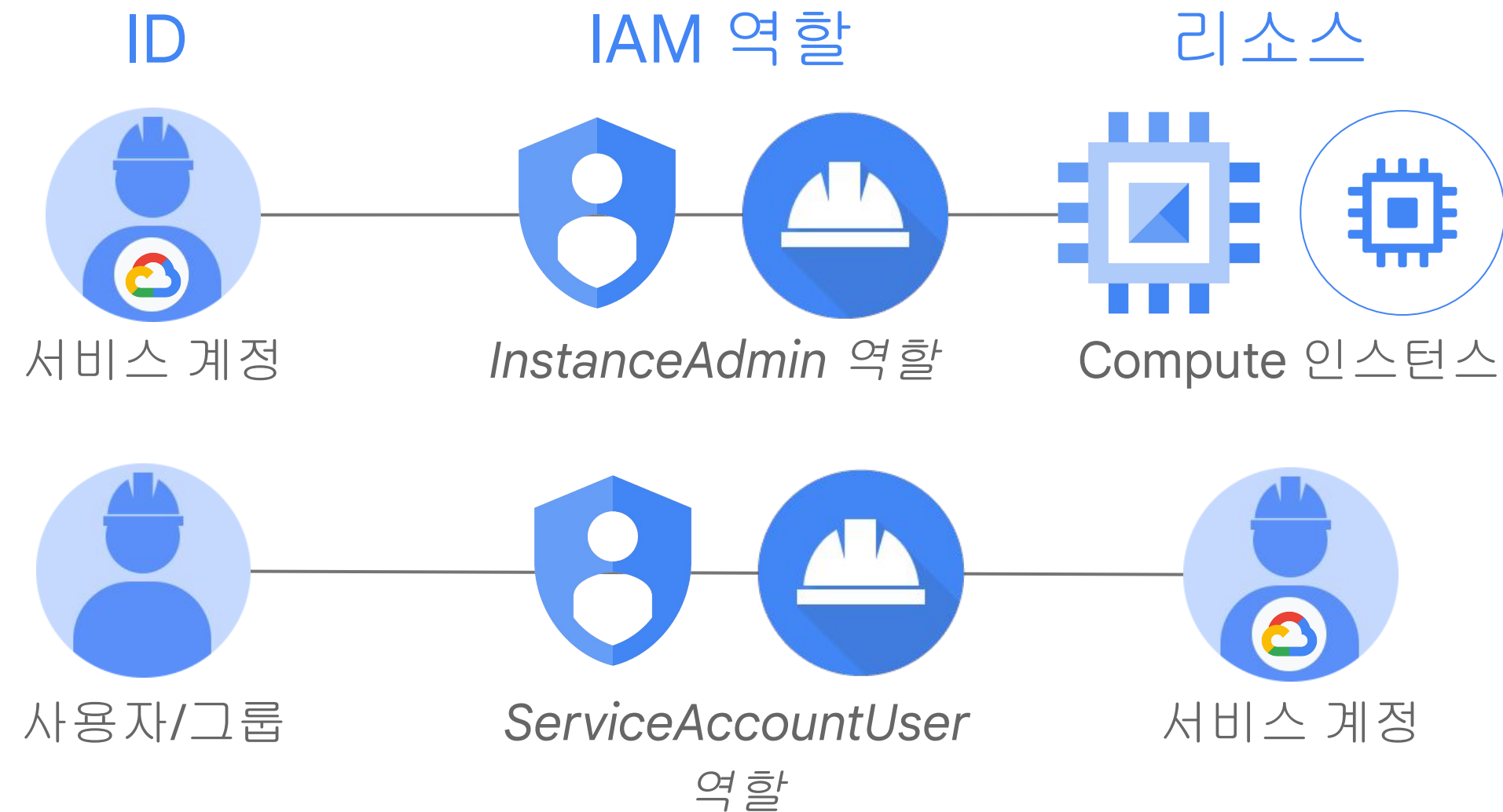
Cloud Datastore

None

- 범위는 인스턴스가 생성된 후에 변경할 수 있습니다.
- 사용자가 만든 서비스 계정의 경우 대신 IAM 역할을 사용하세요.

# 서비스 계정 권한

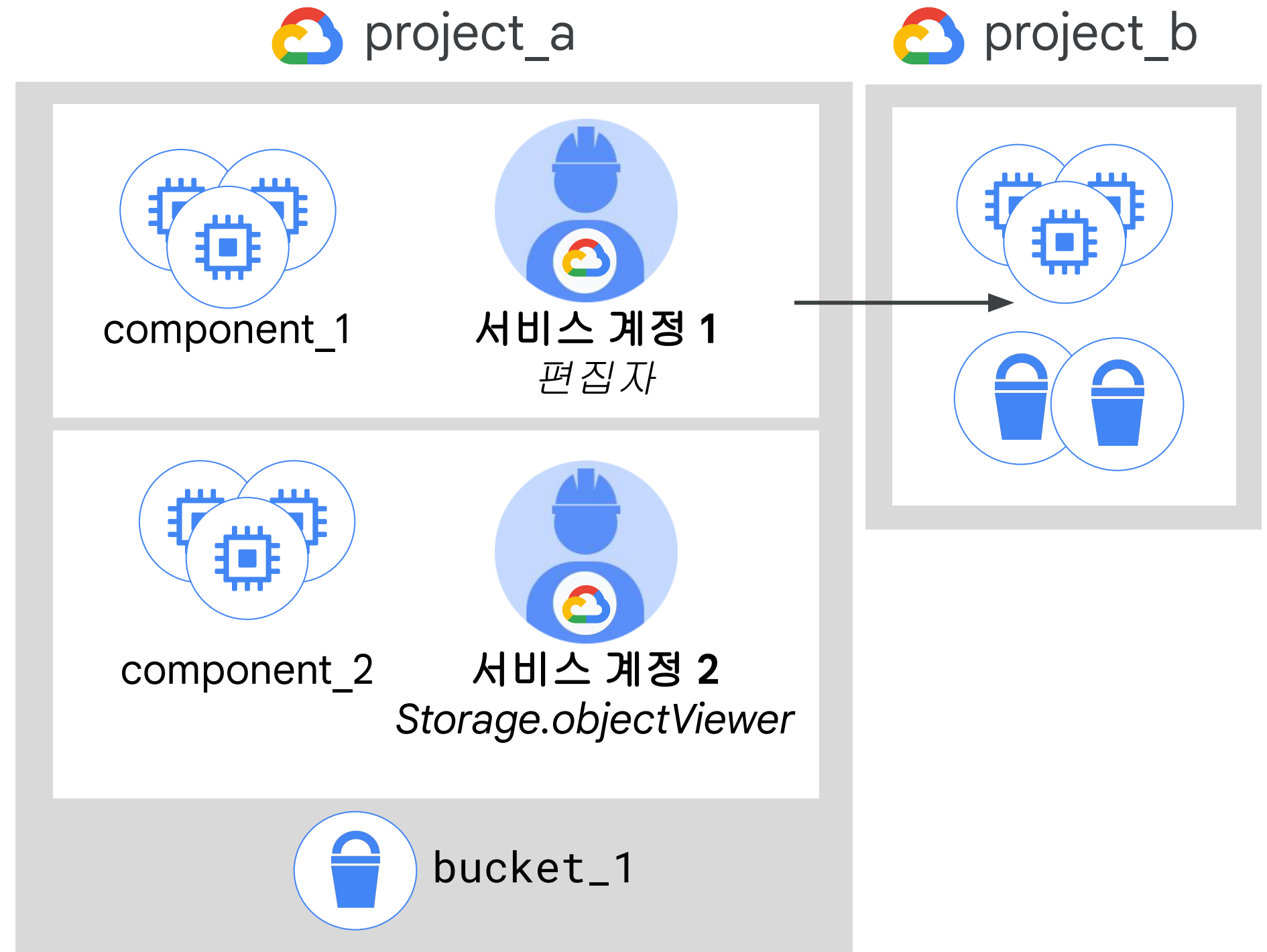
- 기본 서비스 계정: 기본 및 사전 정의된 역할
- 사용자가 만든 서비스 계정: 사전 정의된 역할
- 서비스 계정의 **역할**은 그룹 또는 사용자에게 할당 가능





# 예: 서비스 계정과 IAM

- component\_1을 실행하는 VM에는 서비스 계정 1을 사용하여 project\_b에 대한 편집자 액세스 권한이 부여됩니다.
- component\_2를 실행하는 VM에는 서비스 계정 2를 사용하여 bucket\_1에 대한 objectViewer 액세스 권한이 부여됩니다.
- 서비스 계정 권한은 VM을 다시 생성하지 않고도 변경할 수 있습니다.



# 서비스 계정 키의 두 가지 유형

## Google 관리형 서비스 계정

- 모든 서비스 계정에 Google이 관리하는 키가 있습니다.
- Google은 키의 공개 부분과 비공개 부분을 모두 저장합니다.
- 각 공개 키는 최대 2주 동안 서명에 사용할 수 있습니다.
- 비공개 키는 절대로 직접 액세스할 수 없습니다.

## 사용자 관리형 서비스 계정

- Google에서는 사용자가 관리하는 키의 공개 부분만 저장합니다.
- 비공개 키의 보안에 대한 책임은 사용자에게 있습니다.
- 서비스당 최대 10개의 사용자 관리형 서비스 계정 키를 만들 수 있습니다.
- IAM API, gcloud 또는 콘솔을 통해 관리할 수 있습니다.

# 서비스 계정 키의 두 가지 유형

## Google 관리형 서비스 계정

- 모든 서비스 계정에 Google이 관리하는 키가 있습니다.
- Google은 키의 공개 부분과 비공개 부분을 모두 저장합니다.
- 각 공개 키는 최대 2주 동안 서명에 사용할 수 있습니다.
- 비공개 키는 절대로 직접 액세스할 수 없습니다.

## 사용자 관리형 서비스 계정

- Google에서는 사용자가 관리하는 키의 공개 부분만 저장합니다.
- 비공개 키의 보안에 대한 책임은 사용자에게 있습니다.
- 서비스당 최대 10개의 사용자 관리형 서비스 계정 키를 만들 수 있습니다.
- IAM API, gcloud 또는 콘솔을 통해 관리할 수 있습니다.



# 서비스 계정 키의 두 가지 유형

## Google 관리형 서비스 계정

- 모든 서비스 계정에 Google이 관리하는 키가 있습니다.
- Google은 키의 공개 부분과 비공개 부분을 모두 저장합니다.
- 각 공개 키는 최대 2주 동안 서명에 사용할 수 있습니다.
- 비공개 키는 절대로 직접 액세스할 수 없습니다.

## 사용자 관리형 서비스 계정

- Google에서는 사용자가 관리하는 키의 공개 부분만 저장합니다.
- 비공개 키의 보안에 대한 책임은 사용자에게 있습니다.
- 서비스당 최대 10개의 사용자 관리형 서비스 계정 키를 만들 수 있습니다.
- IAM API, gcloud 또는 콘솔을 통해 관리할 수 있습니다.

사용자 관리형 키를 안전하게 보관하는 것이 중요하며  
이는 만든 사람의 책임



**주의: Google**은 사용자 관리형 비공개 키를  
저장하지 않습니다. 분실한 경우 **Google**에서  
복구를 도와드릴 수 없습니다.

**gcloud** 명령줄 도구를 사용하여 서비스 계정과 연결된 모든 키를 빠르게 나열 가능

```
gcloud iam service-accounts keys list --iam-account user@email.com
```

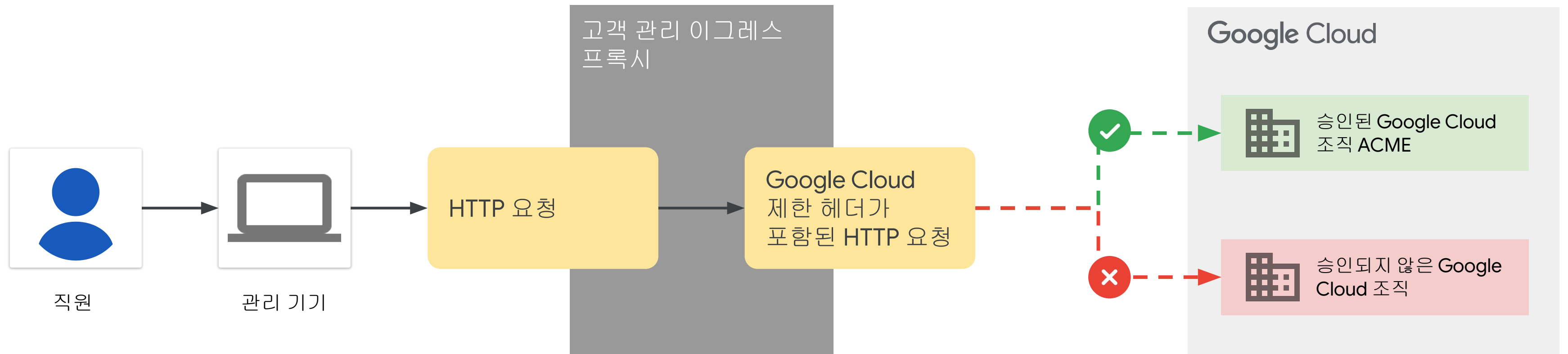


## 조직 액세스 제한

조직 액세스 제한을 사용하면 피싱 또는 내부자 공격을  
통한 데이터 무단 반출을 방지할 수 있습니다.



# 조직 액세스 제한





# IAM 권장 사항

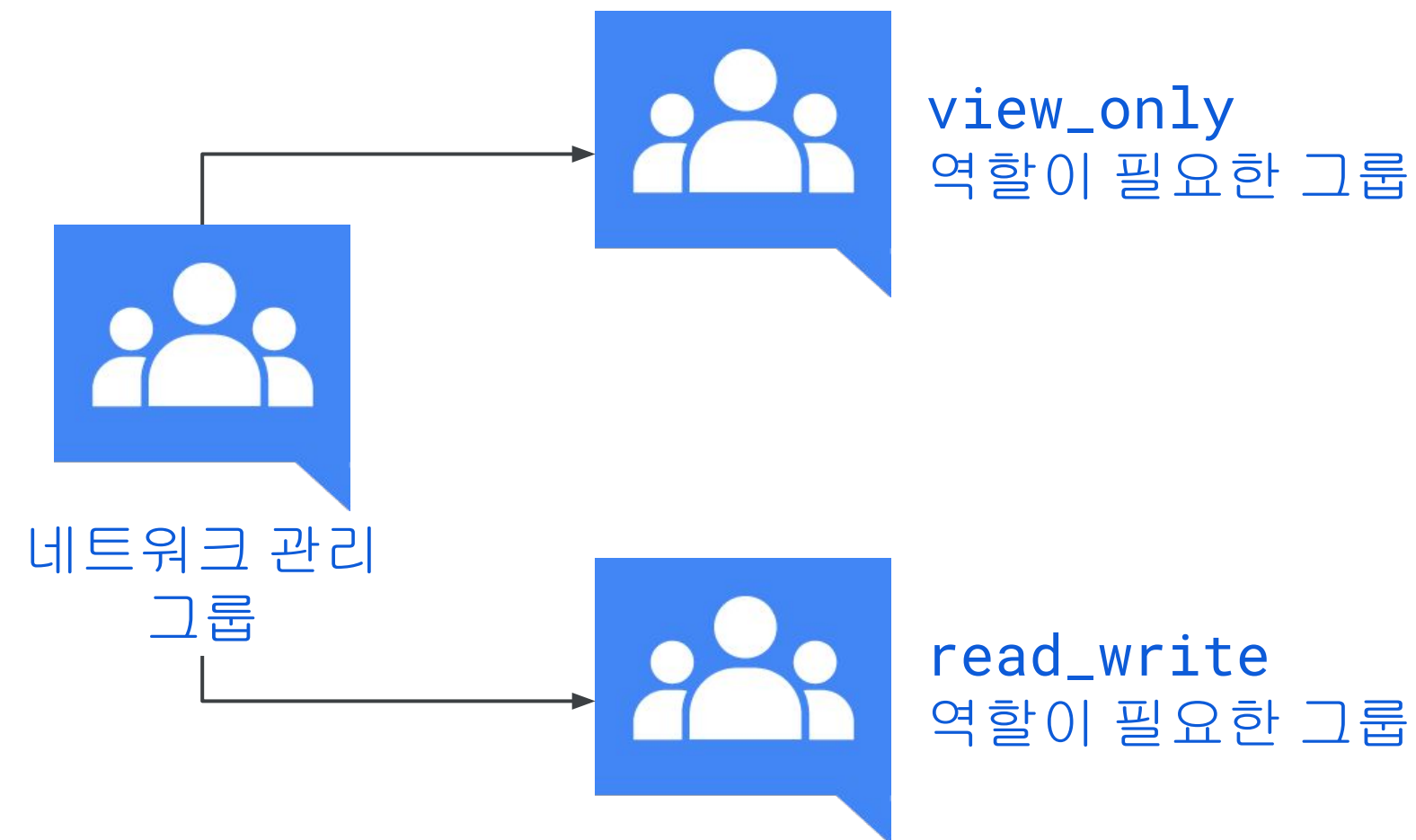
# 리소스 계층 구조의 이해 및 활용

- 프로젝트를 사용하여 동일한 신뢰 경계를 공유하는 리소스를 그룹화합니다.
- 각 리소스에 부여된 정책을 확인하고 상속이 무엇인지 이해해야 합니다.
- 역할을 부여할 때 '최소 권한의 원칙'을 적용합니다.
- Cloud 감사 로그에서 정책을 감사합니다(setiampolicy).
- 정책에 사용되는 그룹 멤버십을 감사합니다.



# 개인 대신 Google 그룹에 역할 부여

- IAM 정책을 변경하는 대신 그룹 멤버십을 업데이트합니다.
- 정책에 사용되는 그룹 멤버십을 감사합니다.
- IAM 정책에 사용되는 Google 그룹의 소유권을 제어합니다.



# 서비스 계정

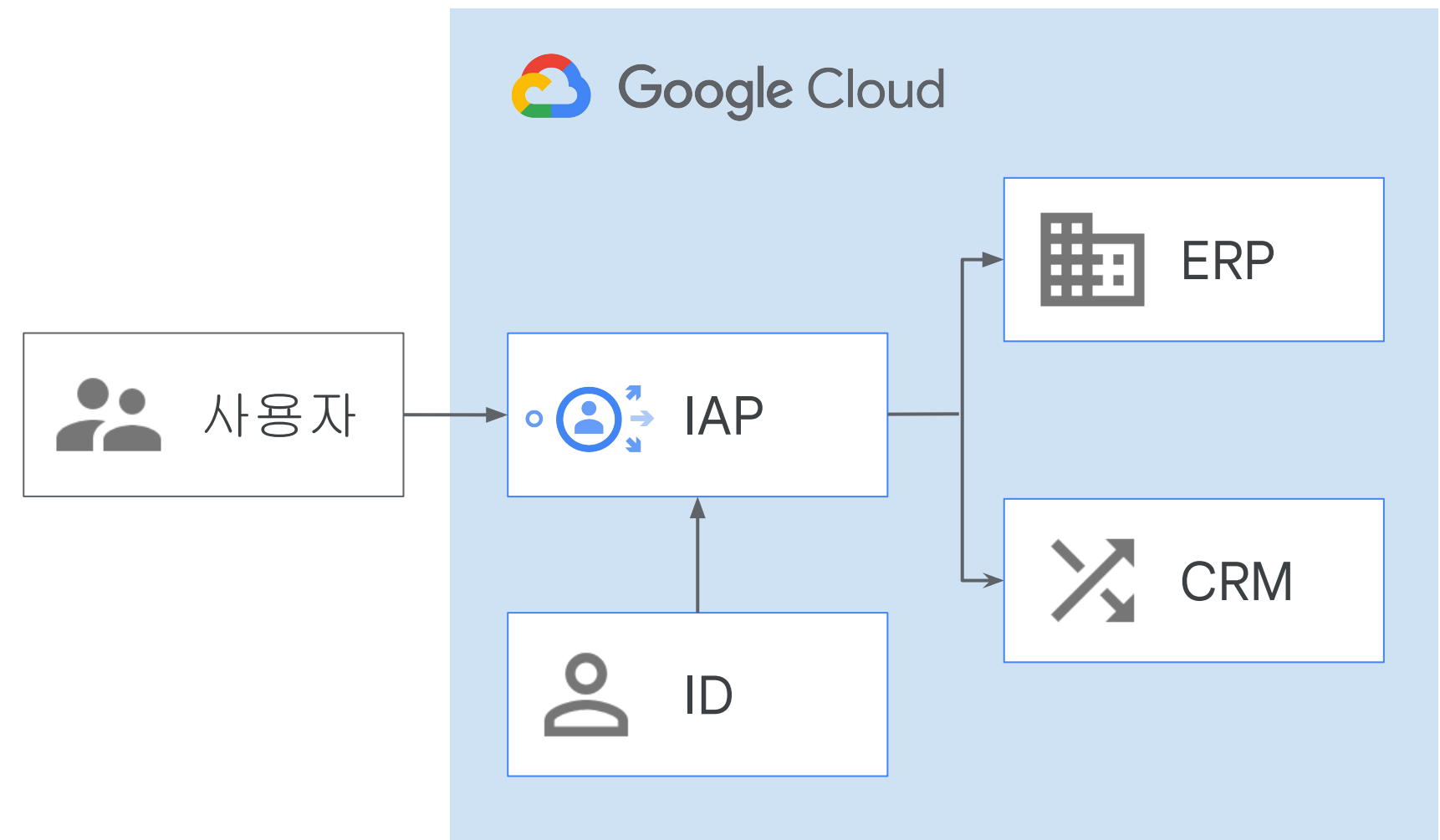
- `serviceAccountUser` 역할을 부여할 때는 주의합니다.
- 서비스 계정을 만들 때 목적을 명확하게 식별하는 표시 이름을 지정합니다.
- 서비스 계정의 경우 이름 지정 규칙을 설정합니다.
- 키 순환 정책 및 방법을 설정합니다.
- `serviceAccount.keys.list()` 메서드로 감사합니다.

# IAP(Identity-Aware Proxy)

애플리케이션 및 리소스에 대한 액세스  
제어 정책 시행:

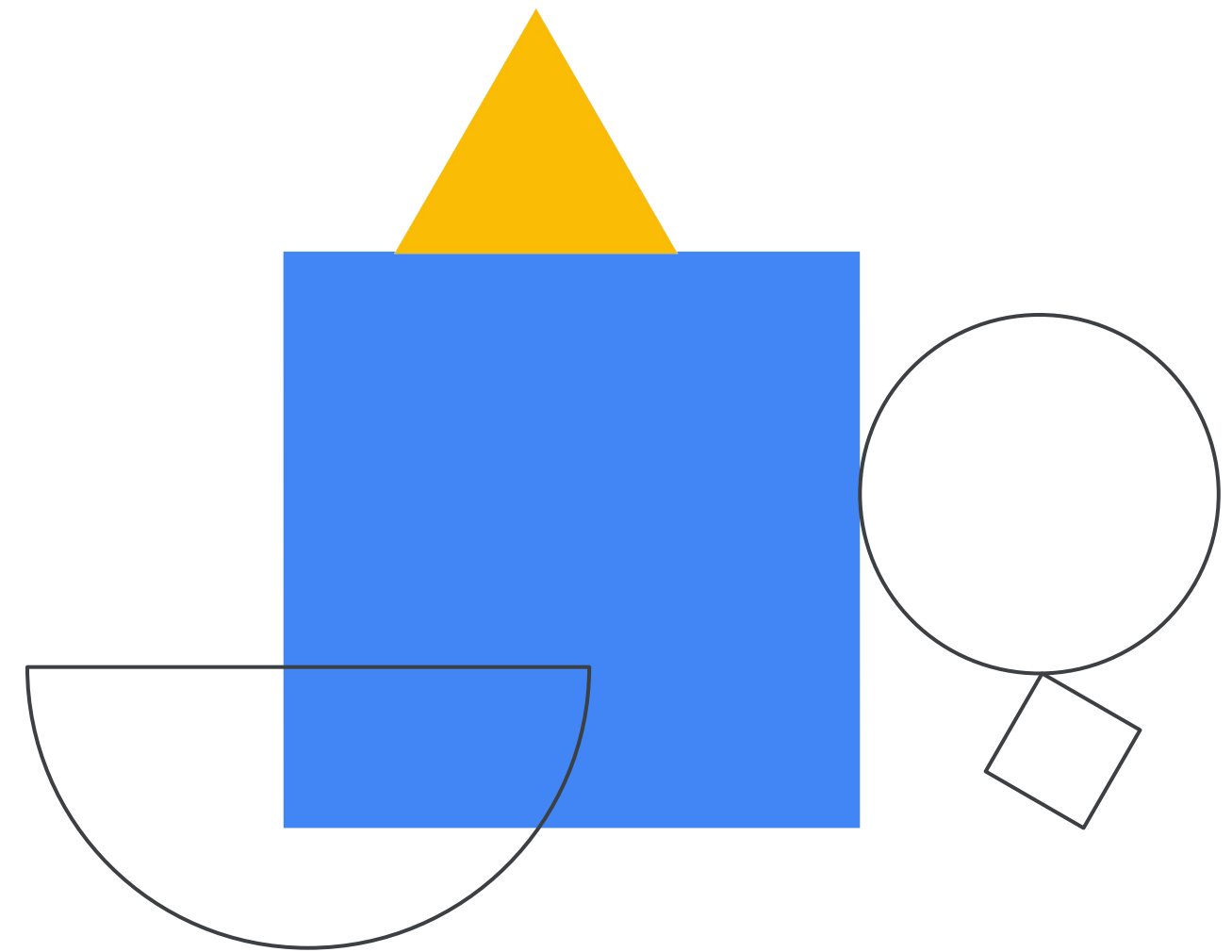
- ID 기반의 액세스 제어
- HTTPS로 액세스할 수 있는  
애플리케이션을 위한 중앙 승인 레이어

IAM 정책은 인증 후 적용됩니다.



# 실습 소개

IAM 살펴보기



# 실습 목표

01

IAM을 사용하여 액세스 제어 구현하기

02

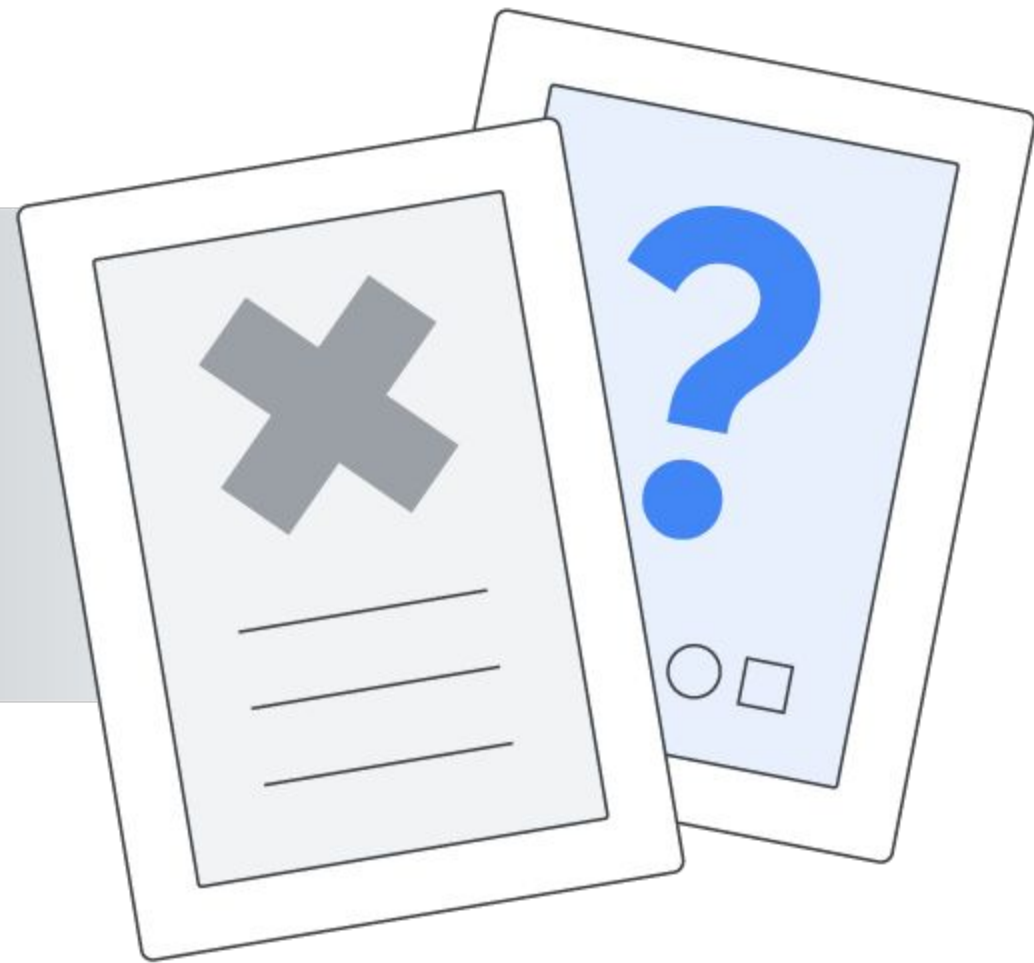
특정 기능 또는 리소스에 대한 액세스 제한하기

03

서비스 계정 사용자 역할 사용하기







# 퀴즈



# 질문 1

## 질문

IAM에서 사용자 액세스를 관리하는 데 주로 사용되는 추상화는 무엇인가요?

- A. 임대, 주기적 사용 권한의 추상화
- B. 역할, 작업 역할의 추상화
- C. 사용자 인증 정보, 인증 토큰의 추상화
- D. 권한, 액세스 권한의 추상화

# 질문 1

## 정답

IAM에서 사용자 액세스를 관리하는 데 주로 사용되는 추상화는 무엇인가요?

- A. 임대, 주기적 사용 권한의 추상화
- B. 역할, 작업 역할의 추상화
- C. 사용자 인증 정보, 인증 토큰의 추상화
- D. 권한, 액세스 권한의 추상화





# 질문 2

## 질문

다음 중 IAM 역할의 유형이 아닌 것은 무엇인가요?

- A. 기본 역할
- B. 사전 정의된 역할
- C. 커스텀 역할
- D. 고급 역할

## 질문 2

### 정답

다음 중 IAM 역할의 유형이 아닌 것은 무엇인가요?

- A. 기본 역할
- B. 사전 정의된 역할
- C. 커스텀 역할
- D. 고급 역할



# 질문 3

## 질문

다음 중 IAM 구성원 유형이 아닌 것은 무엇인가요?

- A. Google 계정
- B. 서비스 계정
- C. Google 그룹
- D. 조직 계정
- E. Cloud ID 도메인
- F. Google Workspace 도메인

## 질문 3

### 정답

다음 중 IAM 구성원 유형이 아닌 것은 무엇인가요?

- A. Google 계정
- B. 서비스 계정
- C. Google 그룹
- D. 조직 계정
- E. Cloud ID 도메인
- F. Google Workspace 도메인



# 검토: Identity and Access Management

